How to roll out Microsoft Copilot without opening a hole in your tenant

A phased, fact-checked checklist for Microsoft 365 admins: licensing, admin roles and Conditional Access, a deep oversharing clean-up (EEEU, sharing links, broken inheritance, ownerless sites, public teams, guests), sensitivity labels and DLP for Copilot, devices, agents, pilot, audit and adoption.

9 phases · 34 steps · Tick each item when its "done when" criterion is true

Phase 1 Prerequisites & licensing about 1–3 days

- [ ] **1.1 Confirm licensing and eligibility**
  Every pilot user has a qualifying base license plus a Microsoft Copilot license
- [ ] **1.2 Get apps, mailboxes and the network ready**
  Apps channel, Exchange Online mailbox, OneDrive and *.cloud.microsoft network access verified
- [ ] **1.3 Run the readiness assessment and pick the admin roles**
  Copilot Optimization Assessment done; AI Administrator and SharePoint Advanced Management roles assigned

Phase 2 Admin roles & identity hardening about 1–2 weeks

- [ ] **2.1 Cut standing admin access with least privilege and PIM**
  Admin roles reviewed; privileged roles eligible (just-in-time) in PIM, not permanent
- [ ] **2.2 Set up emergency access accounts**
  Two cloud-only break-glass accounts with phishing-resistant MFA, excluded from blocking CA policies and monitored
- [ ] **2.3 Require phishing-resistant MFA and block legacy authentication**
  CA policies for phishing-resistant MFA (admins first) and legacy-auth block are On after report-only
- [ ] **2.4 Handle risky users and sign-ins**
  User-risk and sign-in-risk policies in place; Microsoft-managed risk policy reviewed
- [ ] **2.5 Lock down app consent and agent creation**
  User consent restricted, admin consent workflow on; agent blueprint creation decided

Phase 3 Close the holes: oversharing, permissions & guests about 3–8 weeks (the big one)

- [ ] **3.1 Prepare the tooling**
  SAM available, SharePoint Advanced Management Administrator assigned, latest SharePoint Online Management Shell installed
- [ ] **3.2 Take a baseline with the Content Management Assessment**
  Content Management Assessment run; findings list exported and prioritized
- [ ] **3.3 Find the sites with the widest audience (site permissions report)**
  Site permissions snapshot report run for SharePoint and OneDrive; top-exposed sites listed
- [ ] **3.4 Hunt down 'Everyone' and 'Everyone except external users' (EEEU)**
  Item-level EEEU/Everyone reports downloaded; grants removed or rescoped; EEEU hidden from the people picker
- [ ] **3.5 Tame sharing links and external sharing**
  Default link = Specific people; Anyone links expire and are view-only (or off); external sharing limited; sharing link reports reviewed
- [ ] **3.6 Fix broken inheritance and give every site accountable owners**
  Broken-inheritance sites triaged; site ownership policy (minimum 2 owners) active
- [ ] **3.7 Clean up stale content Copilot would otherwise reason over**
  Inactive sites (180+ days) reviewed; archive or retention decisions made
- [ ] **3.8 Fix public teams and Microsoft 365 groups**
  Public teams/groups with sensitive content made private; container labels enforce privacy; group creation policy decided
- [ ] **3.9 Let site owners fix their own sites (site access reviews)**
  Site access reviews sent for high-risk sites; completion tracked

- [ ] **3.10 Put interim guardrails on what you can't fix before launch**
  RCD on high-risk sites under review; RAC on business-critical sites; no new Restricted SharePoint Search
- [ ] **3.11 Review guests and external collaboration**
  Guest invite and guest access restrictions set; recurring guest access reviews running

Phase 4 Protect sensitive data by default: labels & DLP about 2–4 weeks

- [ ] **4.1 Publish a sensitivity label taxonomy**
  Labels published; sensitivity labels for Office files in SharePoint/OneDrive enabled; encryption rights tested
- [ ] **4.2 Stop Copilot processing what it never should (DLP for Copilot)**
  DLP policy on the Microsoft 365 Copilot and Copilot Chat location tested in simulation and turned on
- [ ] **4.3 Decide retention and detection for Copilot interactions**
  Retention for Copilot interactions and audit log retention decided; Insider Risk policies considered

Phase 5 Devices & apps about 1–2 weeks

- [ ] **5.1 Require compliant devices**
  Windows compliance policy assigned; CA requires compliant or hybrid-joined device
- [ ] **5.2 Protect Copilot on phones and unmanaged devices**
  App protection policies for Copilot and Microsoft 365 apps; unmanaged-device access limited
- [ ] **5.3 Manage the Copilot experience on Windows and Edge**
  Copilot key, Edge Copilot policies and update rings configured

Phase 6 Agents & Copilot Studio governance about 1–2 weeks

- [ ] **6.1 Inventory agents and assign owners**
  Agent registry reviewed; ownerless agents blocked or reassigned
- [ ] **6.2 Govern who can build, what agents connect to, and how users sign in**
  Environment strategy, Power Platform data policies and agent authentication enforced

Phase 7 Pilot rollout about 2–6 weeks

- [ ] **7.1 License a pilot group and set the feature policies**
  Pilot group licensed via group-based licensing; web search and Teams meeting policies decided
- [ ] **7.2 Red-team your own tenant**
  Test prompts for sensitive topics run as pilot users; findings fed back into phase 3
- [ ] **7.3 Onboard pilot users**
  Welcome email, AI usage policy link and onboarding experience sent; feedback enabled

Phase 8 Monitoring & audit about Ongoing (set up in ~1 week)

- [ ] **8.1 Use the Copilot audit trail**
  Audit on; CopilotInteraction searches saved; AccessedResources and sensitivity labels reviewed
- [ ] **8.2 Put the clean-up on a schedule**
  Recurring CMA (30 days), DAG snapshot (quarterly) and activity reports (monthly) scheduled
- [ ] **8.3 Track usage and licenses**
  Copilot usage report reviewed monthly; inactive licenses reallocated

Phase 9 User adoption about Ongoing

- [ ] **9.1 Use Microsoft's adoption kits and build champions**
  Success Kit and Launch Day kit used; champions group running; scenario library mapped per department

Owner _____ Change / ticket _____ Date completed _____

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.github.io/guides/secure-copilot-rollout.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.